

VirtuEx 시스템 감사 보고서 (18차)

VirtuEx System Audit Report (18th)

- 감사일: 2026-03-16
- 감사 범위: API 보안, 입력 검증, 에러 처리, 인증/인가, DB 무결성, 서비스 간 통신, 로깅/모니터링, 설정 관리
- 감사 방법: 전체 소스 코드 정적 분석 + API 흐름 추적 + 보안 취약점 패턴 매칭
- 심각도 기준: Critical(즉시 수정) / High(1주 내) / Medium(2주 내) / Low(개선 권장)
- 비고: 본 보고서는 발견 사항만 기록하며, 수정은 포함하지 않음

이전 감사 대비 수정 현황 (17차 → 18차)

이전 이슈	상태	비고
[PW-H-01] 비밀번호 초기화/로그인 속도 제한 부족	수정됨	로그인 5req/분, 비밀번호 초기화 5req/분, SMS 재전송 3req/분 엔드포인트별 @Throttle 추가
[PW-M-01] 비밀번호 초기화 복잡성 검증 미흡	수정됨	resetPassword()에 소문자/숫자/특수문자 검증 추가
[GW-M-01] JwtStrategy localhost 하드코딩	미수정	Docker/K8s 배포 환경에서 장애 가능
[NTF-L-01] 읽음 처리 후 미읽음 카운트 미갱신	수정됨	useMarkAsRead의 onSuccess에 unread-count 캐시 무효화 추가

요약 (Executive Summary)

카테고리	Critical	High	Medium	Low	합계
A. 인증/토큰 보안 (미수정)	1	0	0	0	1
B. API 입력 검증	0	1	2	1	4
C. 에러 처리	0	0	2	1	3
D. CSP/XSS 방어 (미수정)	0	0	1	0	1
E. DB 스키마/데이터 무결성	0	0	2	1	3
F. 서비스 간 통신	0	0	1	1	2
G. 로깅/모니터링	0	0	1	1	2
H. 설정/구성 관리	0	0	0	1	1
I. 미수정 이슈 (이전 차수)	0	0	3	1	4
합계	1	1	12	7	21

A. 인증/토큰 보안 (미수정) — 1건

[SEC-C-01] JWT 액세스 토큰 sessionStorage 저장 — XSS 취약점 (Critical)

현상: JWT 액세스 토큰이 sessionStorage에 저장되어 페이지 내 실행되는 모든 JavaScript에서 접근 가능. TODO 주석으로 "HttpOnly + Secure + SameSite 쿠키로 전환" 필요성이 명시되어 있으나 미수정 **위치:**

frontend/src/stores/auth.ts:37-38, 57-69 **권장:** 액세스 토큰을 HttpOnly 쿠키로 이전. 리프레시 토큰은 이미 쿠키 방식 — 동일 패턴 확장 **심각도:** Critical

B. API 입력 검증 — 4건

[VAL-H-01] 게시물 첨부파일 — 서버 측 파일 크기/타입 재검증 부재 (High)

현상: useUploadCommunityAttachment()가 Base64 인코딩된 파일을 JSON body로 전송. 프론트엔드에서 MIME/크기 검증이 있으나, 백엔드 POST /api/community/posts/:id/attachments에서 수신된 Base64 데이터의 실제 크기와 MIME 타입을 재검증하지 않으면, 악의적 클라이언트가 프론트엔드 검증을 우회하여 대용량 파일 업로드 가능 **위치:**

frontend/src/hooks/useCommunity.ts:321-343, 대응 백엔드 컨트롤러 **권장:** 백엔드에서 Base64 디코딩 후 실제 크기 검증 + magic bytes 기반 MIME 검증 추가 **심각도:** High

[VAL-M-01] 채팅 메시지 — content 길이 제한 미명시 (Medium)

현상: SendMessageDto에 content 필드의 최대 길이 제한이 없음. 악의적 사용자가 매우 긴 메시지(수 MB)를 전송하여 DB 저장 및 다른 사용자의 렌더링 성능 저하 가능 **위치:** backend/services/chat/src/chat/dto/send-message.dto.ts **권장:** @MaxLength(5000) 등 적절한 길이 제한 추가 **심각도:** Medium

[VAL-M-02] 커뮤니티 댓글 — content 길이/빈 문자열 서버 검증 (Medium)

현상: 프론트엔드에서 commentText.trim() 검증 후 전송하지만, 백엔드에서 빈 문자열이나 공백만으로 구성된 댓글에 대한 서버 측 검증이 누락되면 빈 댓글이 저장될 수 있음 **위치:**

frontend/src/app/(main)/community/[id]/page.tsx:264-266, 대응 백엔드 컨트롤러 **권장:** 백엔드 DTO에 @IsNotEmpty(), @MaxLength(2000) 검증 추가 **심각도:** Medium

[VAL-L-01] 주문 수량 — 소수점 자릿수 제한 없음 (Low)

현상: OrderForm.tsx에서 수량 입력 시 .toFixed(8) 포매팅이 있으나, 사용자가 직접 입력 시 소수점 20자리 이상 입력 가능. 백엔드 Decimal 처리에서 정밀도 손실 또는 처리 비용 증가 **위치:**

frontend/src/components/trading/OrderForm.tsx:287, backend/services/order-engine/src/presentation/dto/place-order.dto.ts **권장:** 프론트엔드 입력 시 소수점 8자리 제한 + 백엔드 DTO에 precision 검증 **심각도:** Low

C. 에러 처리 — 3건

[ERR-M-01] 게시물 삭제 실패 — alert() 사용 (Medium)

현상: CommunityPostDetailPage.handleDelete()에서 삭제 실패 시 alert() 사용. 다크 모드 디자인과 불일치하며, 사용자 경험 저하. 다른 에러는 toast 시스템 사용 **위치:**

frontend/src/app/(main)/community/[id]/page.tsx:257 **권장:** useToastStore.getState().addToast(message, 'error') 패턴으로 통일 **심각도:** Medium

[ERR-M-02] AI 분석 — 에러 유형 미구분 (Medium)

현상: handleAiAnalysis()에서 모든 에러를 동일하게 setAiError(true)로 처리. 네트워크 에러, 타임아웃(60초), 서버 500 에러, AI 서비스 불가 등 원인별 안내 없음. 사용자가 재시도 가능 여부를 판단할 수 없음 **위치:**

frontend/src/app/(main)/dashboard/page.tsx:205-208 권장: 에러 유형별 메시지 분기 (timeout → "시간 초과, 재시도", 503 → "AI 서비스 일시 불가" 등) 심각도: Medium

[ERR-L-01] 조회수 증가 API — 실패 시 사일런트 무시 (Low)

현상: api.post(`/api/community/posts/\${id}/view`).catch(() => {}) 형태로 조회수 API 실패를 완전히 무시. 서버 장애를 감지할 수 없음 **위치:** frontend/src/app/(main)/community/[id]/page.tsx:237` 권장: 최소한 console.warn 로깅 추가, 또는 실패 횟수 카운트 후 재시도 로직 심각도: Low

D. CSP/XSS 방어 (미수정) — 1건

[CSP-M-01] 프로덕션 CSP — unsafe-inline 허용 (Medium)

현상: 프로덕션 환경에서 CSP script-src 에 'unsafe-inline' 포함. 공격자가 주입한 인라인 스크립트가 실행 가능하여 XSS 방어력 약화 위치: frontend/next.config.ts:9 권장: 'unsafe-inline' 을 nonce 기반 또는 hash 기반 CSP로 대체 심각도: Medium

E. DB 스키마/데이터 무결성 — 3건

[DB-M-01] 커뮤니티 게시물 content — Base64 이미지로 인한 무제한 크기 (Medium)

현상: TipTap 에디터에서 이미지를 Base64로 삽입하면 게시물 content 필드가 수 MB에 달할 수 있음. DB Text 타입은 이론적으로 무제한이지만, 게시물 목록 API에서 content 를 포함하여 반환하면 응답 크기 폭발 위치:

backend/services/user-auth/prisma/schema.prisma (CommunityPost.content),
frontend/src/components/ui/RichEditor.tsx:103-109 권장: 게시물 목록에서 content를 요약(첫 200자)만 반환, 이미지는 별도 업로드 URL 참조 심각도: Medium

[DB-M-02] authorName 비정규화 — 사용자명 변경 시 불일치 (Medium)

현상: CommunityPost, CommunityComment, CommunityStrategy, CommunityStrategyComment 모두 authorName 을 비정규화 필드로 저장. 사용자가 이름을 변경하면 기존 게시물/댓글의 이름이 갱신되지 않아 불일치 발생 위치: backend/services/user-auth/prisma/schema.prisma (CommunityPost, CommunityComment 등) 권장: 이름 변경 시 캐스케이드 업데이트 메커니즘 추가, 또는 읽기 시 User 테이블 조인 심각도: Medium

[DB-L-02] 프록시 컨트롤러 — Record<string, any> 타입 사용 (Low)

현상: (req as Record<string, any>).user?.id 로 사용자 정보를 추출하여 TypeScript 타입 검사를 우회 위치: backend/services/api-gateway/src/proxy/order-proxy.controller.ts:49, 185, 212, 256, 276 권장: 기존 @CurrentUser() 데코레이터 활용으로 타입 안전한 사용자 추출 심각도: Low

F. 서비스 간 통신 — 2건

[INT-M-01] JwtStrategy — SERVICE_HOST 대신 localhost 하드코딩 (Medium)

현상: JwtStrategy에서 user-auth 서비스 URL을 http://localhost:\${port} 로 생성. ProxyService는 SERVICE_HOST 환경변수를 사용하지만 JwtStrategy는 하드코딩. Docker/K8s 배포 시 통신 실패 위치: backend/services/api-gateway/src/auth/jwt.strategy.ts:32 권장: configService.getOrThrow<string>('SERVICE_HOST') 사용 심각도: Medium

[INT-L-01] 주문 서비스 — portfolio 서비스 HTTP 호출 타임아웃 공유 (Low)

현상: OrderService 가 market-data와 portfolio 서비스에 HTTP 요청 시 동일한 `httpTimeout` 사용. market-data 의 가격 조회는 빠르지만 portfolio의 잔고 차감은 트랜잭션 포함으로 더 오래 걸릴 수 있음 **위치:**

`backend/services/order-engine/src/application/services/order.service.ts:47` **권장:** 서비스별 타임아웃 분리 (market-data: 3초, portfolio: 10초 등) **심각도:** Low

G. 로깅/모니터링 — 2건

[LOG-M-01] 채팅 삭제 — 감사 로그 미기록 (Medium)

현상: ChatService.deleteMessage() 와 deleteRoom() 에서 관리자의 삭제 행위에 대한 감사 로그가 없음. 누가 언제 어떤 메시지/방을 삭제했는지 추적 불가 **위치:** `backend/services/chat/src/chat/chat.service.ts:461-514`

권장: 삭제 전 `this.logger.log(\ Admin ${userId} deleted message/room ${id} `)`` 감사 로그 추가 **심각도:** Medium

[LOG-L-01] 주문 수정 — 이전/이후 값 비교 로그 미기록 (Low)

현상: MatchingEngineService.modifyOrderInBook() 에서 수정 로그는 있으나, 이전 가격/수량과 새 가격/수량의 비교 정보가 포함되지 않음 **위치:** `backend/services/order-engine/src/domain/services/matching-engine.service.ts:397-399`

권장: 로그에 `prev_price/prev_qty → new_price/new_qty` 형태의 변경 내역 포함 **심각도:** Low

H. 설정/구성 관리 — 1건

[CFG-L-01] 환경변수 — ENCRYPTION_KEY 폴백으로 JWT_SECRET 사용 (Low)

현상: auth.service.ts:113-114 에서 ENCRYPTION_KEY 미설정 시 JWT_SECRET 을 암호화 키로 사용. JWT 서명 과 주민번호 암호화에 동일 키를 사용하면, JWT_SECRET 유출 시 주민번호도 복호화 가능 **위치:**

`backend/services/user-auth/src/application/services/auth.service.ts:113-114` **권장:** 프로덕션 에서 ENCRYPTION_KEY 필수 설정 + JWT_SECRET과 분리 검증 **심각도:** Low

I. 미수정 이슈 (이전 차수) — 4건

[CS-M-01] 클라이언트 사이드 캔들스틱 집계 4h/1d (Medium)

현상: 4시간/1일 인터벌의 경우 클라이언트가 최대 5000개 1분봉을 가져와 JavaScript로 집계. 모바일 기기에서 상당한 연산 부하 **위치:** `frontend/src/hooks/useMarket.ts:149-219` **심각도:** Medium

[A11Y-M-02] 이미지 alt/lazy loading — DOMPurify 보안과 트레이드오프 (Medium)

현상: 커뮤니티 게시글에서 DOMPurify가 `<img>` 태그의 `src` 속성을 제거하여 보안 확보. 그러나 사용자 콘텐츠 내 이미지에 `alt`, `loading="lazy"` 속성도 함께 제거됨 **위치:**

`frontend/src/app/(main)/community/[id]/page.tsx:372` **심각도:** Medium

[CM-M-02] TipTap 이미지 크기/해상도 제한 — 5MB 제한만 존재 (Medium)

현상: RichEditor에서 5MB 파일 크기 제한은 있으나, 이미지 해상도(픽셀) 제한이 없음. 10000x10000 해상도 이미지가 Base64로 변환되어 게시글에 포함 가능 **위치:** `frontend/src/components/ui/RichEditor.tsx:86-102` **심각도:** Medium

[ORD-M-01] 주문 내역 — 커스텀 날짜 범위 피커 미구현 (Medium)

현상: 주문 내역 페이지에 날짜 범위 필터가 없어, 전체 기간의 주문을 조회/필터링할 수밖에 없음 위치:

frontend/src/app/(main)/orders/page.tsx 심각도: Medium

종합 의견

18차 감사에서는 총 21건의 이슈가 발견되었습니다. 17차 감사에서 발견된 비밀번호 초기화 속도 제한(PW-H-01), 비밀번호 복잡성(PW-M-01), 알림 캐시 갱신(NTF-L-01) 3건이 정상 수정된 것을 확인하였습니다.

Critical 1건(JWT 토큰 sessionStorage 저장)은 지속적으로 지적되는 핵심 보안 과제입니다. High 1건(첨부파일 서버 측 재검증 부재)은 프론트엔드 검증 우회를 통한 악의적 파일 업로드를 허용할 수 있어 조속한 대응이 필요합니다.

새로 발견된 이슈 중 채팅 메시지/댓글 길이 제한 부재(VAL-M-01/02), TipTap Base64 이미지의 DB 저장 문제(DB-M-01), 채팅 삭제 감사 로그 부재(LOG-M-01)는 서비스 성숙도를 높이기 위해 개선이 필요한 항목입니다.

JwtStrategy의 localhost 하드코딩(INT-M-01)은 프로덕션 배포 시 장애를 유발할 수 있으므로 배포 전 반드시 수정을 권장합니다.

본 보고서는 자동 생성된 감사 결과이며, 수정 사항은 포함되지 않습니다.